

Projet CYNA — Politique de Sécurité de l'Information (PSI)

Rédacteur(s) : Équipe Sécurité / Antoine A (SecOps)

Date de mise à jour : 25 juin 2026

Version : V1.0

1. Introduction et Principes Directeurs

La Politique de Sécurité de l'Information (PSI) du projet CYNA définit l'ensemble des règles, directives et mécanismes de protection mis en œuvre pour sécuriser l'infrastructure multi-sites (Genève et Paris). Elle repose sur une approche rigoureuse de défense en profondeur et applique de manière stricte le modèle Zero Trust (Never Trust, Always Verify).

L'objectif principal de cette politique est de garantir les trois piliers fondamentaux de la sécurité des données et des systèmes :

- Confidentialité (C) : Protection des données sensibles contre tout accès non autorisé.
- Intégrité (I) : Garantie que les données et les configurations système ne sont pas altérées de manière illégitime.
- Disponibilité (D) : Maintien en condition opérationnelle de l'infrastructure face aux pannes et aux attaques cybernétiques.

2. Contrôle d'Accès et Principe du Moindre Privilège

L'accès aux ressources du système d'information de CYNA est régi par une compartimentation stricte des droits d'accès administratifs et applicatifs selon le principe du moindre privilège (PoLP - Principle of Least Privilege).

2.1 Administration de l'écosystème Windows Server Core

- L'infrastructure Active Directory s'appuie sur l'édition Windows Server Core (AD1 et

AD2) afin de réduire la surface d'attaque en éliminant l'interface graphique locale.

- L'administration locale est désactivée ou fortement restreinte par stratégie de groupe (GPO).
- L'administration à distance s'effectue exclusivement via le protocole sécurisé WinRM configuré en HTTPS (TLS 1.3), avec un accès limité aux seuls membres du groupe de sécurité Admin_Infrastructure.

2.2 Administration des Hôtes Linux (Debian)

- L'accès direct en tant que super-utilisateur (root) est formellement proscrit sur l'ensemble des serveurs Debian (hébergeant le moteur Docker et la stack de sécurité).
- Toutes les tâches d'administration requièrent l'utilisation de la commande sudo, avec une

journalisation systématique et obligatoire des commandes exécutées vers le SIEM central.

2.3 Comptes de Service et Environnement Conteneurisé

- L'utilisation de comptes génériques ou partagés est strictement interdite. Chaque application ou processus s'exécute sous l'identité d'un compte de service dédié (comptes de services gérés par le domaine ou Managed Service Accounts - gMSA pour l'environnement Windows).
- Pour l'environnement Docker hébergeant la stack Wazuh, les conteneurs sont configurés pour s'exécuter avec des privilèges restreints (Non-Root Containers) au sein des espaces de noms Linux (namespaces), limitant ainsi drastiquement les risques d'évasion de conteneur.

1. Chiffrement des Données

La protection des informations contre l'interception réseau et le vol physique de matériel est assurée par le déploiement de protocoles de chiffrement robustes. État de la donnée Périmètre d'application Technologie et Algorithme

En transit (In Motion) Liaisons inter-sites (Tunnel
VPN Paris - Genève)

VPN IPsec, chiffrement
AES-256-GCM, SHA-384,
Diffie-Hellman Groupe 14
minimum.

En transit (In Motion) Flux d'administration et
interfaces de gestion
(pfSense, Wazuh Dashboard)

Protocole HTTPS avec
support exclusif de TLS 1.3
(protocoles obsolètes SSLv3,
TLS 1.0, 1.1 et 1.2
désactivés).

Au repos (At Rest) Volumes de stockage de
l'hyperviseur Hyper-V local

Chiffrement BitLocker Drive
Encryption validé par puce
TPM (Trusted Platform
Module).

Au repos (At Rest) Hôtes Linux Debian (Données
persistantes Wazuh, volumes
/var/lib/docker)

Chiffrement par bloc LUKS
(Linux Unified Key Setup)
basé sur l'algorithme
AES-XTS-256.

1. Gestion des Logs et Centralisation SIEM

La traçabilité, l'auditabilité et la détection précoce des menaces reposent
sur une architecture

de journalisation centralisée.

4.1 Collecte de la Télémétrie

L'ensemble de la télémétrie de sécurité est centralisé au sein d'une pile Wazuh
(SIEM/XDR)

déployée en mode conteneurisé (Single-Node) sur un hôte Debian dédié. Des

agents légers

Wazuh sont installés sur tous les endpoints critiques (Contrôleurs de domaine Windows Core, serveurs membres, hôtes applicatifs Linux). Les journaux d'événements (Security logs Windows AD, logs d'accès SSH, appels système Docker) sont transmis en temps réel via un canal chiffré TLS vers le Wazuh Manager.

4.2 Politique de Rétention

- Logs Actifs : Conservés et indexés de manière dynamique dans les index de Wazuh

pendant une durée minimale de 90 jours pour permettre les analyses en temps réel et les corrélations d'alertes.

- Archivage à froid : Au-delà de 90 jours, un mécanisme automatisé compresse et

exporte les logs bruts vers un espace de stockage froid, sécurisé et immuable, garantissant l'intégrité des données historiques pour d'éventuelles analyses forensiques ultérieures.

1. Procédure de Confinement et Réponse aux Incidents

En cas de détection d'un comportement suspect, d'une compromission avérée ou d'une alerte de sécurité majeure émise par le SIEM, une procédure de confinement strict est immédiatement enclenchée afin de neutraliser la menace et d'empêcher les mouvements latéraux :

2. Isolation réseau de l'hôte : Utilisation du module de réponse active (Active Response)

de l'agent Wazuh. Ce mécanisme permet de bloquer automatiquement et instantanément l'intégralité des flux réseau au niveau du pare-feu local de la machine affectée, à l'exception unique du flux de communication sécurisé avec le serveur Wazuh Manager.

3. Confinement logique au niveau du périmètre : Si l'incident persiste ou menace de se propager, l'équipe d'administration applique un cloisonnement strict via le pare-feu pfSense, isolant le VLAN concerné (VLAN 10 Genève ou VLAN 11 Paris) du reste du réseau d'entreprise et coupant le transit à travers le tunnel VPN IPsec.
4. Analyse forensique et Remédiation : La machine virtuelle affectée sur l'hyperviseur Hyper-V est figée par la capture d'un instantané (snapshot) à des fins d'analyse mémoire.
Le système compromis est ensuite nettoyé, mis à jour de manière managée via le serveur WSUS ou les playbooks Ansible, puis réintégré en production après validation formelle du responsable sécurité.